

Report finale riassuntivo del corso

Autore: Francesco Sardi

Data: 20/02/2026

Oggetto: Report finale riassuntivo del corso.

Executive Summary

Il presente documento ha lo scopo di illustrare le attività pratiche e teoriche svolte durante il corso, fornendo un report generale delle competenze acquisite.

Il documento è strutturato in 4 sezioni principali:

- **Esercizio 1:** Utilizzo e analisi tramite Windows PowerShell.
- **Esercizio 2:** Analisi di malware e ricerca di IOC.
- **Esercizio 3:** Information Gathering e port scanning tramite Nmap.
- **Esercizio 4:** Analisi di un attacco SQL Injection tramite Wireshark.

Esercizio 1: Utilizzare Windows PowerShell

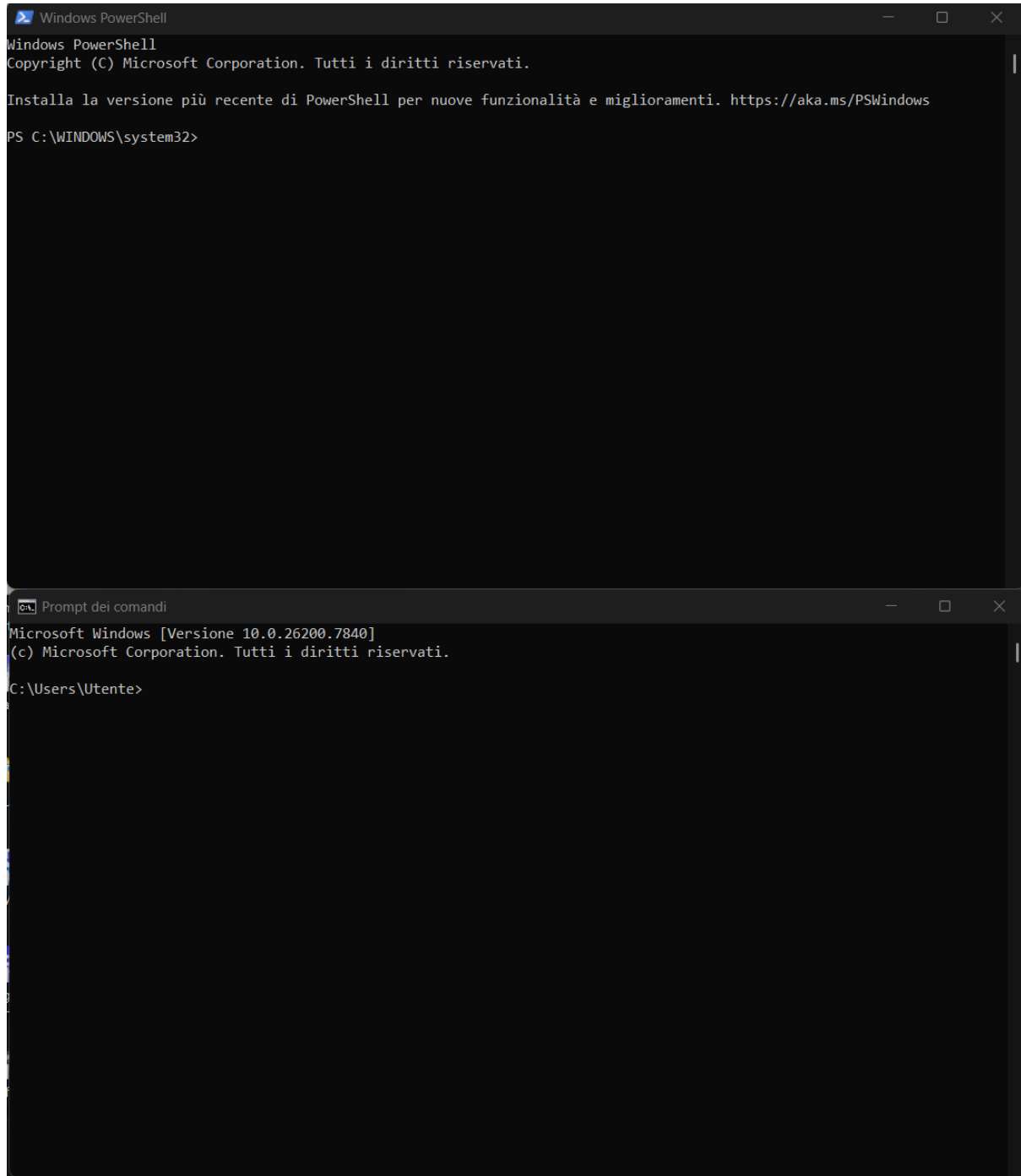
Obiettivi

- **Parte 1:** Accedere alla console PowerShell.
- **Parte 2:** Esplorare e confrontare i comandi del Prompt dei Comandi e di PowerShell.
- **Parte 3:** Esplorare i *cmdlet*.
- **Parte 4:** Esplorare il comando netstat usando PowerShell.
- **Parte 5:** Svuotare il cestino usando PowerShell.

Per questo test è stata utilizzata una macchina Windows con PowerShell installata e connessione a internet attiva.

Parte 1:

Accesso a PowerShell e al Prompt dei comandi di Windows tramite la barra di ricerca del menu Start.



Parte 2:

Esecuzione del comando *dir* su entrambi i terminali per analizzare l'output.

Quali sono gli output del comando *dir*?

In entrambi i terminali viene mostrato l'elenco dei file e delle sottocartelle presenti nella directory corrente. La differenza principale risiede nel fatto che l'output di Windows PowerShell è formattato, offrendo la possibilità di estrapolare e manipolare maggiori informazioni, mentre l'output del cmd restituisce testo grezzo con una formattazione basilare.

Successivamente, è stato testato il comando di verifica della connettività: “ping www.libero.it”

Quali sono i risultati?

I risultati sono positivi, confermando che l'host è correttamente connesso a internet. L'output del comando ICMP è il medesimo sia in PowerShell che in cmd.

```
PS C:\Users\Utente> ping www.libero.it

Esecuzione di Ping d31d9gezsytlz8.cloudfront.net [108.157.188.35] con 32 byte di dati:
Risposta da 108.157.188.35: byte=32 durata=6ms TTL=248
Risposta da 108.157.188.35: byte=32 durata=5ms TTL=248
Risposta da 108.157.188.35: byte=32 durata=5ms TTL=248
Risposta da 108.157.188.35: byte=32 durata=5ms TTL=248

Statistiche Ping per 108.157.188.35:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
Tempo approssimativo percorsi andata/ritorno in millisecondi:
    Minimo = 5ms, Massimo = 6ms, Medio = 5ms
PS C:\Users\Utente>
```

```
cmd Prompt dei comandi
C:\Users\Utente>ping www.libero.it

Esecuzione di Ping d31d9gezsytlz8.cloudfront.net [108.157.188.35] con 32 byte di dati:
Risposta da 108.157.188.35: byte=32 durata=5ms TTL=248
Risposta da 108.157.188.35: byte=32 durata=5ms TTL=248
Risposta da 108.157.188.35: byte=32 durata=5ms TTL=248
Risposta da 108.157.188.35: byte=32 durata=5ms TTL=248

Statistiche Ping per 108.157.188.35:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
Tempo approssimativo percorsi andata/ritorno in millisecondi:
    Minimo = 5ms, Massimo = 5ms, Medio = 5ms
C:\Users\Utente>
```

Parte 3:

Esplorare i cmdlet

I comandi PowerShell (*cmdlet*) seguono la sintassi "Verbo-Nome". Inserendo in PowerShell il comando `Get-Alias dir` si ottengono informazioni sul comando sottostante.

Qual è il comando PowerShell per `dir`?

Il comando nativo PowerShell per `dir` è `Get-ChildItem`. `dir` è semplicemente un alias, utile per mostrare il contenuto della directory corrente.

Parte 4:

Esplorare il comando `netstat` usando PowerShell

Eseguendo `netstat -h` è possibile visualizzare l'help e le opzioni disponibili per il comando. Successivamente, tramite il comando `netstat -r`, è stata visualizzata la tabella di routing dell'host.

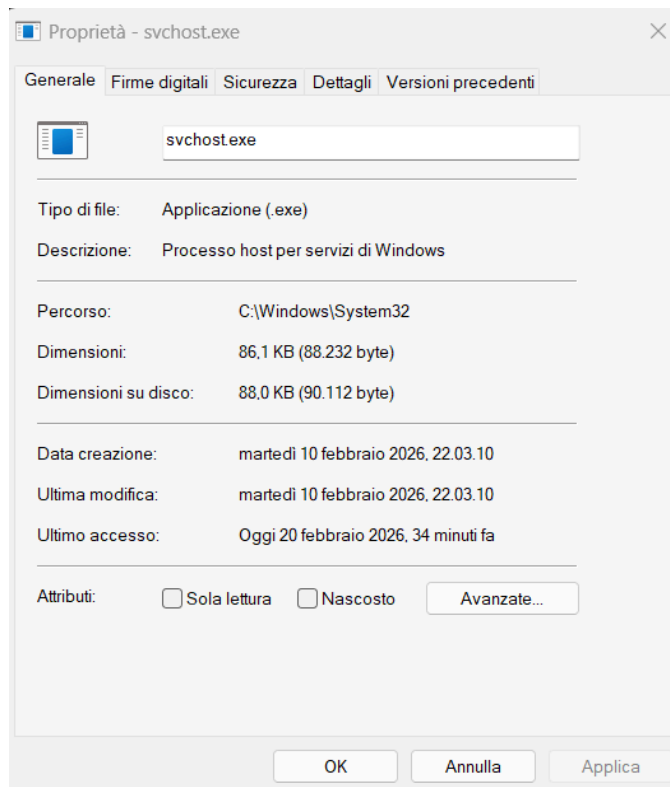
Qual è il gateway IPv4? Il gateway IPv4 sulla mia rete è **192.168.1.254**.

```
IPv4 Tabella route
=====
Route attive:
  Indirizzo rete      Mask      Gateway      Interfaccia Metrica
  0.0.0.0             0.0.0.0    192.168.1.254 192.168.1.50    25
```

Avviando PowerShell con privilegi di amministratore e aprendo il Task Manager (*ordinato per PID*), è stata selezionata una connessione specifica visualizzata tramite il comando `netstat -abno` per analizzare le proprietà.

Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

È possibile ottenere numerose informazioni sul processo, tra cui: il tipo di file, il percorso assoluto, le dimensioni, le date (*creazione, modifica, ultimo accesso*), i permessi di sicurezza, le firme digitali e le versioni precedenti.



Parte 5:

Svuotare il Cestino

In questa fase, il cestino di Windows viene svuotato direttamente dalla riga di comando. Tramite il cmdlet Clear-RecycleBin, vengono eliminati tutti gli elementi presenti nel cestino.

```
PS C:\WINDOWS\system32> clear-recyclebin

Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida (il valore predefinito è "S"): t
PS C:\WINDOWS\system32>
```

Cosa è successo ai file nel Cestino?

Gli elementi presenti nel cestino sono stati eliminati in modo definitivo dal sistema.

Domanda di Riflessione:

PowerShell è stato sviluppato per l'automazione delle attività e la gestione della configurazione. Usando internet, ricerca comandi che potresti usare per semplificare i tuoi compiti come analista di sicurezza. Registra le tue scoperte.

Alcuni cmdlet essenziali per il lavoro di un analista SOC o di sicurezza includono:

- **Get-Process:** Utile per elencare tutti i processi in esecuzione su un sistema. È fondamentale per la threat hunting, poiché i malware spesso si nascondono o si iniettano nei processi in esecuzione.
- **Get-NetTCPConnection:** Permette di verificare tutte le connessioni TCP correnti, le porte aperte e il loro stato, sostituendo in modo più efficiente netstat.
- **Get-FileHash:** Fondamentale per calcolare l'hash di un file (es. *SHA256*) e confrontarlo con database di threat intelligence (come *VirusTotal*) per identificare file malevoli.

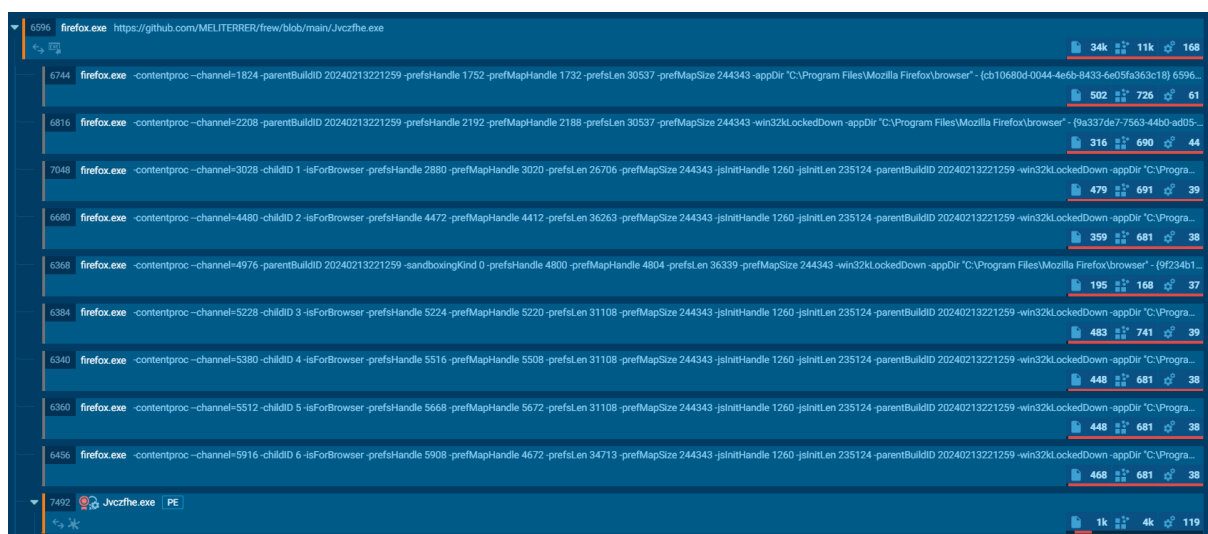
Esercizio 2: Studio IOC

In questa fase viene analizzata l'esecuzione di un potenziale malware in un ambiente sandbox, al fine di estrarre e spiegare le minacce rilevate.

Link Any.run: “ <https://app.any.run/tasks/9a15871843fe-45ce-85b366203dbc2281/> ”

Da una prima analisi dell'ambiente di sandboxing, si evince che il sistema operativo target è Windows. Il malware genera richieste di connessione sospette sfruttando il browser Firefox. Si nota inoltre un collegamento a una repository GitHub, una tecnica comune per nascondere e scaricare payload secondari da siti legittimi e fidati.

L'albero dei processi mostra la creazione di alcuni processi figli apparentemente normali, ma l'ultimo log evidenzia l'esecuzione di un file senza il consenso dell'utente.



Primo IOC: Esecuzione del file Jvczfhe.exe

The screenshot displays the Any.Run interface for a process named **Jvczfhe.exe** (ID 7492, PE). The process tree shows several child processes:

- 7520 cmd.exe /c timeout 21 & exit**
- 7528 conhost.exe 0xffffffff -ForceV1**
- 7572 timeout.exe 21**
- 5152 InstallUtil.exe**
- 1356 WerFault.exe -u -p 7492 -s 2676**

Below the process tree, the **Process details** section for ID 7492 is marked as **Suspicious**. It lists three critical warnings:

- Warning 3**: Executes application which crashes
- T1012 Query Registry (2)**:
 - Reads security settings of Internet Explorer
 - Checks Windows Trust Settings
- T1059.003 Windows Command Shell (1)**:
 - Starts CMD.EXE for commands execution

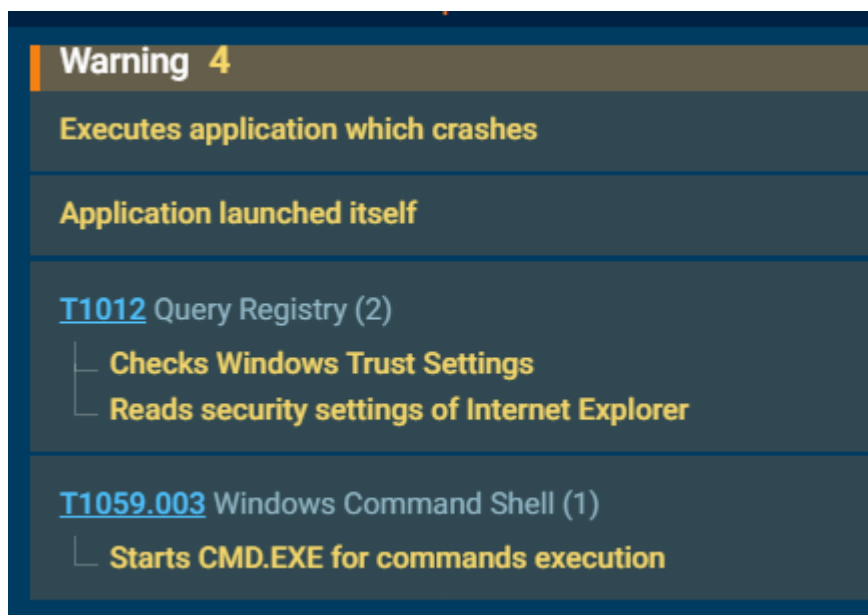
L'analisi fornita da Any.run evidenzia tre comportamenti critici:

1. **Evasione**: Un timeout/sleep di 21 secondi, tecnica spesso usata per eludere le analisi automatizzate delle sandbox.
2. **Process Injection**: L'avvio di **InstallUtil.exe**. Sebbene sia un tool legittimo di Windows, viene spesso sfruttato per iniettare payload malevoli. Il processo tenta inoltre di comunicare su una porta non standard.
3. **Reconnaissance**: Lettura delle chiavi di registro relative alle impostazioni di sicurezza di Internet Explorer e dei trust settings di Windows.

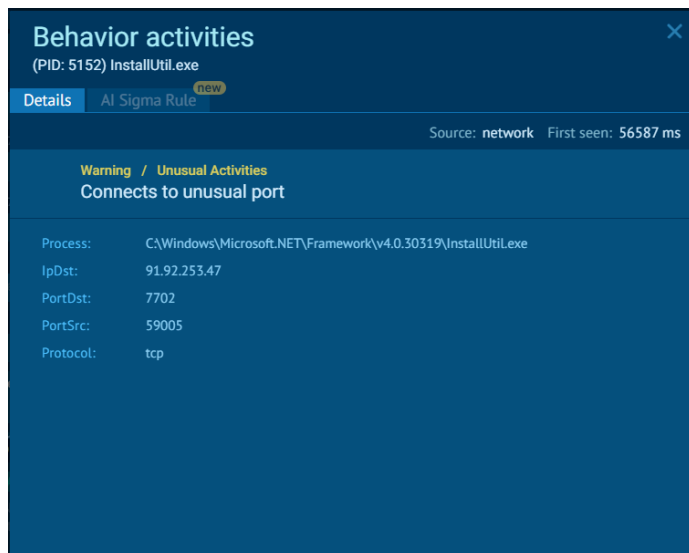
Successivamente, si nota l'esecuzione di un secondo file, **Muadnrd.exe**, che presenta una firma comportamentale quasi identica al precedente. Anch'esso esegue comandi tramite cmd ed evoca il processo di segnalazione errori **WerFault.exe**.



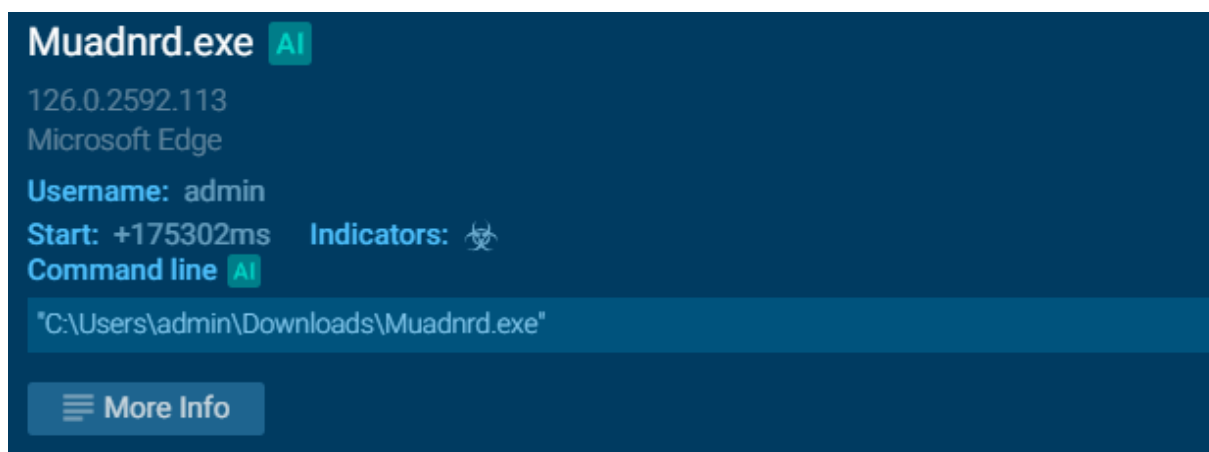
Warning relativi al file Muadnrd.exe



Come accennato, il processo iniettato InstallUtil.exe tenta di stabilire una connessione Command and Control su una porta inusuale (7702 TCP). A livello di remediation, si consiglia di bloccare preventivamente questa porta sul firewall per bloccare il traffico in uscita.



Inoltre, dall'analisi di Muadnrd.exe, si nota che il file è stato scaricato nella directory: C:\Users\admin\Downloads\Muadnrd.exe.



Relazione Finale

L'analisi ha permesso di ricostruire la catena di esecuzione di un attacco e di estrarre i relativi Indicatori di Compromissione (*IOC*) per prevenire infezioni.

I file iniziale (*Jvczfhe.exe*) funge da Loader. Sebbene non sembri eseguire attività malevoli dirette, attua tecniche di evasione delle difese (*pausa di 21 secondi*) e di ricognizione (*lettura chiavi di registro e lingua del sistema*). Successivamente, tenta di iniettare codice in un processo legittimo di Windows (*InstallUtil.exe*) per bypassare i controlli di sicurezza.

È emerso un forte collegamento con un secondo file, *Muadnrd.exe* (posizionato in C:\Users\admin\Downloads\), il quale presenta la stessa identica firma comportamentale del primo. È altamente probabile che si tratti di una copia del malware originale creata per garantirsi persistenza o per eseguire il payload malevolo finale.

Il controllo remoto della macchina compromessa viene stabilito tramite il tentativo di connessione verso l'IP esterno 91.92.253.47 su una porta non usuale (*TCP 7702*).

IOC trovati :

- **Esecuzione ritardata** (timeout 21).
- **Process Injection** (InstallUtil.exe).
- **Scoperta**: Lettura chiavi di registro e lingua di sistema per profilazione (Fingerprinting).

Indicatori di Rete :

- **IPv4 Destination: 91.92.253.47 (Porta TCP: 7702)**

Indicatori di Sistema :

- **Nomi file sospetti**: Jvczfhe.exe, Muadnrd.exe
- **Percorsi file**: C:\Users\admin\Downloads\Muadnrd.exe

Esercizio 3:

Information Gathering tramite Nmap

In questo esercizio viene utilizzato Nmap per effettuare la fase di ricognizione sulla superficie di attacco di un target. Questa fase è vitale per mappare le porte aperte e i servizi esposti. Verrà utilizzata una macchina virtuale Cyber Ops Workstation.

Obiettivi

- **Parte 1**: Esplorazione del tool Nmap.
- **Parte 2**: Scansione delle porte aperte (*Locale, Rete locale, Remoto*).

Parte 1:

Esplorazione

Aperto il terminale nella VM CyberOps Workstation, digitando il comando *man nmap* si accede al manuale ufficiale del tool.

NMAP(1)	Nmap Reference Guide	NMAP(1)
NAME		
nmap - Network exploration tool and security / port scanner		
SYNOPSIS		
nmap [<i>Scan Type...</i>] [<i>Options</i>] { <i>target specification</i> }		
DESCRIPTION		
Nmap ("Network Mapper") is an open source tool for network exploration and security auditing. It was designed to rapidly scan large networks, although it works fine against single hosts. Nmap uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics. While Nmap is commonly used for security audits, many systems and network administrators find it useful for routine tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime. The output from Nmap is a list of scanned targets, with supplemental information on each depending on the options used. Key among that information is the "interesting ports table". That table lists the port number and protocol, service name, and state. The state is either open, filtered, closed, or unfiltered. Open means that an application on the target machine is listening for connections/packets on that port. Filtered means that a firewall, filter, or other network obstacle is blocking the port so that Nmap cannot tell whether it is open or closed. Closed ports have no application listening on them, though they could open up at any time. Ports are classified as unfiltered when they are responsive to Nmap's probes, but Nmap cannot determine whether they are open or closed. Nmap reports the state combinations open filtered and closed filtered when it cannot determine which of the two states describe a port. The port table may also include software version details when version detection has been requested. When an IP protocol scan is requested (-sO), Nmap provides information on supported IP protocols rather than listening ports.		

Cos'è Nmap?

Per cosa viene usato nmap?

Nmap è un tool open source fondamentale per la *network exploration*, utile per effettuare ricognizioni sia su grandi network che su singoli host. Tramite l'invio di pacchetti IP grezzi, Nmap permette di ricevere informazioni cruciali sul sistema operativo, sull'eventuale presenza di filtri o firewall in uso e, in particolare, sui servizi in esecuzione sulle varie porte di rete. Il risultato di queste scansioni è un report dettagliato che classifica lo stato di ogni porta analizzata: risulta aperta se un'applicazione è in ascolto e accetta connessioni, chiusa se nessun servizio la sta utilizzando (*pur essendo accessibile*), oppure filtrata quando un ostacolo di rete blocca i pacchetti, impedendo a Nmap di capirne il reale stato. Infine, una porta è considerata non filtrata se risponde ai test ma il tool non riesce a stabilire con certezza se sia aperta o chiusa; nei casi più dubbi, il software restituisce stati combinati (*come aperta/filtrata*) per fornire il quadro più accurato possibile.

Tramite il flag *?Example*, è possibile consultare gli esempi pratici forniti dalla documentazione.

```
EXAMPLES
Here are some Nmap usage examples, from the simple and routine to a little more complex and esoteric. Some actual IP addresses and domain names are used to make things more concrete. In their place you should substitute addresses/names from your own network. While I don't think port scanning other networks is or should be illegal, some network administrators don't appreciate unsolicited scanning of their networks and may complain. Getting permission first is the best approach.

For testing purposes, you have permission to scan the host scanme.nmap.org. This permission only includes scanning via Nmap and not testing exploits or denial of service attacks. To conserve bandwidth, please do not initiate more than a dozen scans against that host per day. If this free scanning target service is abused, it will be taken down and Nmap will report Failed to resolve given hostname/IP: scanme.nmap.org. These permissions also apply to the hosts scanme2.nmap.org, scanme3.nmap.org, and so on, though those hosts do not currently exist.

nmap -v scanme.nmap.org

This option scans all reserved TCP ports on the machine scanme.nmap.org. The -v option enables verbose mode.
```

Qual è il comando nmap usato nell'esempio?

Cosa fanno le opzioni **-A** e **-T4**?

Il comando usato è: *nmap -v -A -T4 scanme.nmap.org*

- **-A (Aggressive Scan):** Abilita un set avanzato di scansioni che include il rilevamento del sistema operativo (*OS detection*), la rilevazione della versione dei servizi (*Version detection*), l'esecuzione degli script di default di Nmap e il traceroute.
- **-T4 (Timing Template):** Regola la velocità della scansione. Il livello 4 (*Aggressive*) accelera i tempi di esecuzione, presumendo di trovarsi su una rete veloce e affidabile.

```
-A (Aggressive scan options)
This option enables additional advanced and aggressive options. Presently this enables OS detection (-O), version scanning (-sV), script scanning (-sC) and traceroute (--traceroute). More features may be added in the future. The point is to enable a comprehensive set of scan options without people having to remember a large set of flags. However, because script scanning with the default set is considered intrusive, you should not use -A against target networks without permission. This option only enables features, and not timing options (such as -T4) or verbosity options (-v) that you might want as well. Options which require privileges (e.g. root access) such as OS detection and traceroute will only be enabled if those privileges are available.
```

Parte 2:

Scansione delle porte aperte

Inizialmente è stata effettuata una scansione sul localhost tramite il comando *nmap -A -T4 localhost*.

```
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 06:41 -0500
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000061s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 0          0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.81 seconds
```

Quali porte e servizi sono aperti sul localhost?

- **Porta 21 (tcp):** Aperta, servizio FTP attivo.
- **Porta 22 (tcp):** Aperta, servizio SSH attivo.

Scansione della Rete Locale: Tramite i comandi di rete, sono stati ricavati l'IP e la subnet mask della macchina.

- **IP:** 10.0.2.15
- **Subnet Mask:** 255.255.255.0 (/24)

```
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 84945sec preferred_lft 84945sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86261sec preferred_lft 14261sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

A quale rete appartiene la VM e quanti host sono attivi?

La VM risiede nella rete **10.0.2.0/24**. Avviando la scansione della rete con la VM impostata in modalità "NAT", Nmap individua un solo host attivo (*la VM stessa*). Questo accade perché il NAT isola la macchina in una rete privata virtuale. Per ottenere una scansione reale dell'intera LAN fisica, la scheda di rete della VM deve essere impostata in modalità "*Bridged*", permettendole di ottenere un IP direttamente dal router fisico della rete.

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 06:50 -0500
Nmap scan report for 10.0.2.15
Host is up (0.000041s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.2.15
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 117.91 seconds
```

Scansione di un Server Remoto:

Lo step successivo prevede la scansione del server *scanme.nmap.org*, un host fornito appositamente per scopi didattici. Il comando eseguito è *nmap -A -T4 scanme.nmap.org*.

Risultati della scansione:

- **Quali porte e servizi sono aperti?**
 - Porta 22 (*tcp*): servizio SSH.
 - Porta 53 (*tcp*): servizio DNS.
 - Porta 80 (*tcp*): servizio web HTTP.
- **Quali porte e servizi sono filtrati?** L'output indica la presenza di 997 porte TCP in stato *filtered*.
- **Qual è l'indirizzo IP risolto del server?** 45.33.32.156.
- **Qual è il sistema operativo target?** Linux.

```
[analyst@secOps ~]$ nmap -A scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 07:46 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.17s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
53/tcp    open  domain       dnsmasq 2.78
| dns-nsid:
|_  bind.version: dnsmasq-2.78
80/tcp    open  tcpwrapped
|_ http-title: Go ahead and ScanMe!
|_ http-favicon: Nmap Project
|_ http-server-header: Apache/2.4.7 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 56.42 seconds
```

Domanda di Riflessione:

Nmap è uno strumento potente per l'esplorazione e la gestione della rete. Come può Nmap aiutare con la sicurezza della rete? Come può Nmap essere usato da un attore malevolo come strumento nefasto?

Dal lato difensivo, Nmap è essenziale per l'auditing continuo: permette di scoprire servizi esposti accidentalmente, porte non necessarie e software non aggiornato, aiutando a ridurre la superficie d'attacco.

Dal lato offensivo, è lo strumento principe della fase di Reconnaissance. Viene utilizzato per mappare l'infrastruttura bersaglio e identificare i vettori d'ingresso vulnerabili prima di lanciare un exploit.

Esercizio 4:

Analisi di un attacco SQL Injection (SQLi)

In questo esercizio viene utilizzato Wireshark per ispezionare il file PCAP di una cattura di rete contenente un attacco SQL Injection su un database MySQL.

Obiettivi

- **Parte 1:** Caricare il file PCAP in Wireshark.
- **Parte 2-6:** Tracciare, visualizzare e analizzare le query iniettate per comprendere l'esfiltrazione dei dati.

Parte 1:

Analisi del traffico

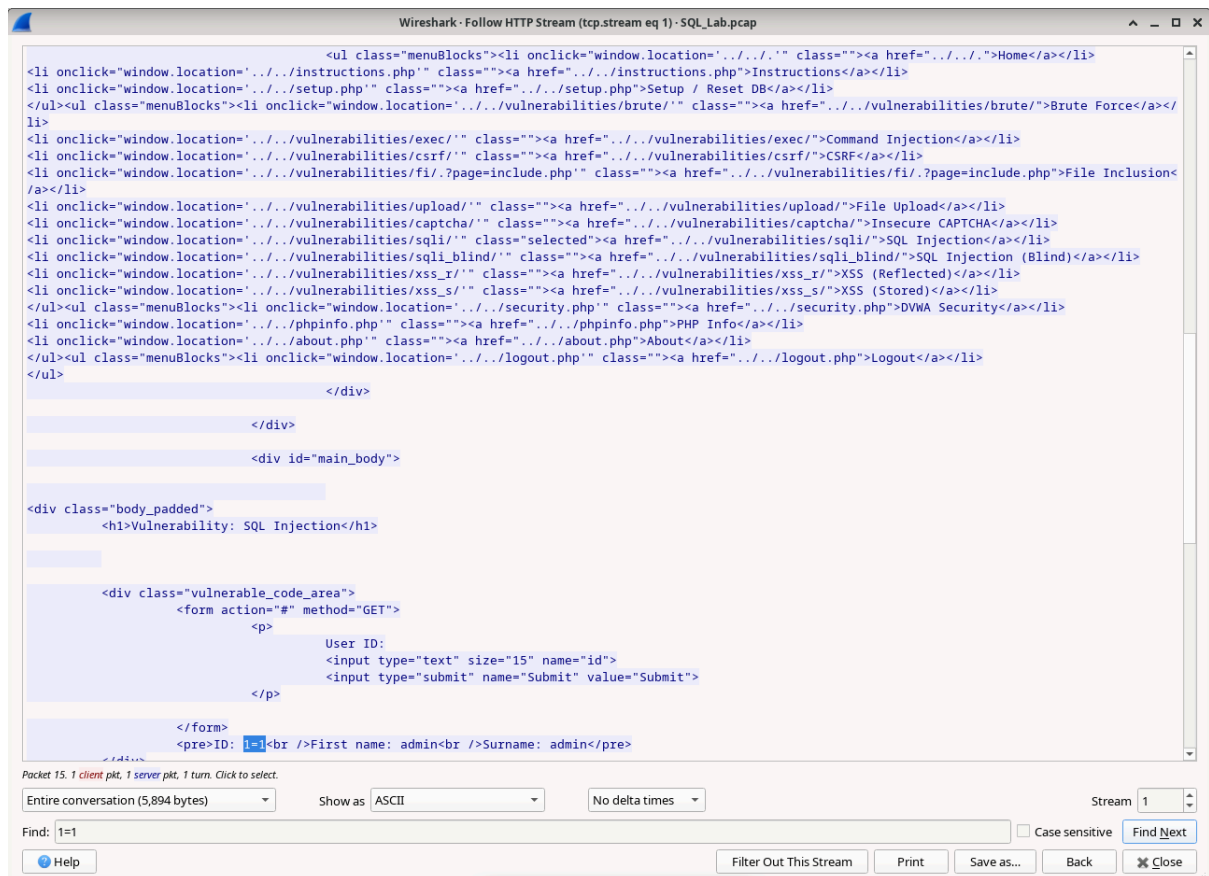
Il file analizzato rappresenta un attacco SQLi della durata di circa 8 minuti.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.2.15	10.0.2.15	TCP	74	15614 → 25614 [SYN, ACK] Seq=0 Ack=1 Win=28968 Len=0 MSS=1460 SACK_PERM TSval=38535 TSecr=45838 WS=128
2	0.000315	10.0.2.15	10.0.2.4	TCP	74	80 → 35614 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=45838 TSecr=38535
3	0.000349	10.0.2.4	10.0.2.15	HTTP	654	POST /dwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)
4	0.000681	10.0.2.4	10.0.2.15	TCP	66	80 → 35614 [ACK] Seq=1 Ack=589 Win=38208 Len=0 TSval=38536 TSecr=45838
5	0.002149	10.0.2.15	10.0.2.4	HTTP	438	HTTP/1.1 302 Found
6	0.005700	10.0.2.15	10.0.2.4	TCP	66	35614 → 80 [ACK] Seq=589 Ack=365 Win=38336 Len=0 TSval=45840 TSecr=38536
7	0.005700	10.0.2.4	10.0.2.15	HTTP	496	GET /dwa/index.php HTTP/1.1
8	0.014383	10.0.2.4	10.0.2.15	HTTP	3187	HTTP/1.1 200 OK (text/html)
9	0.015485	10.0.2.15	10.0.2.4	TCP	66	35614 → 80 [ACK] Seq=1019 Ack=3406 Win=36480 Len=0 TSval=45843 TSecr=38539
10	0.015485	10.0.2.4	10.0.2.15	HTTP	429	GET /dwa/dwa/css/main.css HTTP/1.1
11	0.068625	10.0.2.4	10.0.2.15	HTTP	1511	HTTP/1.1 200 OK (text/css)
12	0.070480	10.0.2.15	10.0.2.4	HTTP	536	GET /dwa/vulnerabilities/sql/7?id=1x3D1&Submit=Submit HTTP/1.1
13	174.254430	10.0.2.4	10.0.2.15	TCP	66	80 → 35638 [ACK] Seq=1 Ack=471 Win=235 Len=0 TSval=82101 TSecr=98114
14	174.254581	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (text/html)
15	174.257989	10.0.2.15	10.0.2.4	HTTP	577	GET /dwa/vulnerabilities/sql/7?id=1x27*or*1x3D1*union*select*database%2829%2C*user%2829%29%28Submit=Submit HTTP/1.1
16	200.490531	10.0.2.4	10.0.2.15	TCP	66	80 → 35640 [ACK] Seq=1 Ack=512 Win=235 Len=0 TSval=93660 TSecr=111985
17	220.490637	10.0.2.15	10.0.2.4	HTTP	1918	HTTP/1.1 200 OK (text/html)
18	220.493085	10.0.2.15	10.0.2.4	HTTP	630	GET /dwa/vulnerabilities/sql/7?id=1x27*or*1x3D1*union*select*database%2829%2C*user%2829%29%28Submit=Submit HTTP/1.1
19	277.727722	10.0.2.4	10.0.2.15	TCP	66	80 → 35642 [ACK] Seq=1 Ack=505 Win=236 Len=0 TSval=107970 TSecr=129156
20	277.727871	10.0.2.15	10.0.2.4	HTTP	1955	HTTP/1.1 200 OK (text/html)
21	277.732200	10.0.2.15	10.0.2.4	HTTP	659	GET /dwa/vulnerabilities/sql/7?id=1x27*or*1x3D1*union*select*null%2C*table_name*from*information_schema.tables%28Submit=Submit HTTP/1.1
22	313.710129	10.0.2.4	10.0.2.15	TCP	66	80 → 35644 [ACK] Seq=1 Ack=594 Win=236 Len=0 TSval=116966 TSecr=139951
23	313.710277	10.0.2.15	10.0.2.4	HTTP	1954	HTTP/1.1 200 OK (text/html)
24	313.712414	10.0.2.15	10.0.2.4	HTTP	680	GET /dwa/vulnerabilities/sql/7?id=1x27*or*1x3D1*union*select*null%2C*table_name*from*information_schema.tables%28Submit=Submit HTTP/1.1
25	383.277032	10.0.2.4	10.0.2.15	TCP	66	80 → 35666 [ACK] Seq=1 Ack=615 Win=236 Len=0 TSval=134358 TSecr=160821
26	383.277811	10.0.2.15	10.0.2.4	HTTP	4868	HTTP/1.1 200 OK (text/html)
27	383.284389	10.0.2.15	10.0.2.4	HTTP	685	GET /dwa/vulnerabilities/sql/7?id=1x27*or*1x3D1*union*select*user%2C*password*from*users%28Submit=Submit HTTP/1.1
28	441.004070	10.0.2.4	10.0.2.15	TCP	66	80 → 35668 [ACK] Seq=1 Ack=620 Win=236 Len=0 TSval=148990 TSecr=178379
29	441.004427	10.0.2.15	10.0.2.4	HTTP	2091	HTTP/1.1 200 OK (text/html)
30	441.007206	10.0.2.15	10.0.2.4	HTTP		

Quali sono i due indirizzi IP coinvolti in questo attacco in base alle informazioni visualizzate?

- **Sorgente (Attaccante):** 10.0.2.4
- **Destinazione (Server Target):** 10.0.2.15

Selezionando il pacchetto numero 13 (*una richiesta HTTP GET*) e seguendo lo stream TCP, è possibile ispezionare il payload dell'attacco in chiaro. L'attaccante inietta la stringa **1=1**. Questa tecnica viene utilizzata nella fase iniziale (*ricognizione della vulnerabilità*) per forzare una condizione sempre vera. Se il sito restituisce un risultato imprevisto senza errori, conferma all'attaccante che l'input non è sanitizzato e che il form è vulnerabile alle SQL Injection.



Ispezionando il pacchetto 19, si rileva una query di tipo **UNION** basata sull'estrazione di informazioni di sistema. L'attaccante riesce a estrarre il nome del database e l'utente in uso.

- **Nome Database:** dvwa
- **Utente Database:** root@localhost

```

</form>
<pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select da
tatabase(), user()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Hack<br />Surname:
Me</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select database(),
user()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: dvwa<br />Surname: root@localho
st</pre>

```

Seguendo lo stream HTTP del pacchetto 22, l'attaccante esegue una query per determinare la versione del DBMS.

```

</form>
<pre>ID: 1' or 1=1 union select null, version()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null
, version()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Hack<br />Surname: Me</p
re><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version()#<b
r />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>

```

Qual è la versione del database?

La versione estratta è 5.7.12-0ubuntu1.1.

Procedendo con l'analisi (*pacchetto 25*), l'attaccante passa all'enumerazione dello schema del database interrogando `information_schema.tables`.

[illegible]

L'output di questa query restituisce l'elenco delle tabelle, permettendo all'attaccante di individuare quelle contenenti dati sensibili (come la tabella "users").

Nella fase finale dell'attacco (*pacchetto 28*), la SQL Injection viene sfruttata per esfiltrare il contenuto della tabella utenti, estraendo username e hash delle password.

```
</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Gordon<br />Surname: Brown</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Hack<br />Surname: Me</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pablo<br />Surname: Picasso</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: 5f4dcc3b5aa765d618327deb882cf99</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: gordon<br />Surname: e9918a4c8b38d5f26085367892e03</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 13d718708: 8d3533d75ae2c3966d7e0d4f6c69216b<br />ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 0d107d90f5bbe40cade3de5c7e19e9b7</pre>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d618327deb882cf99</pre>
</div>
```

Quale utente possiede l'hash della password 8d3533d75ae2c3966d7e0d4fcc69216b?

Qual'è la password in chiaro?

- **Nome utente:** 1337
- **Password in chiaro:** charley

Hash	Type	Result
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

Domande di Riflessione :

1. Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?
2. Naviga in internet ed esegui una ricerca per “prevenire attacchi di SQL injection”. Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?

Oggi giorno quasi tutti i siti web si basano su database che comunicano tramite linguaggio SQL. Il rischio principale è che, se non protetti adeguatamente, questi dati sensibili possano essere estratti, alterati o addirittura cancellati. La gravità dell'attacco SQL Injection varia molto in base alle intenzioni dell'attaccante e al tipo di informazioni che mira a raccogliere o distruggere.

Metodi di prevenzione:

- **Sanitizzazione e Validazione dell'input:** La principale azione preventiva è verificare rigorosamente i dati inseriti dall'utente (*anche tramite espressioni regolari - regex*) per bloccare o "ripulire" caratteri speciali e sequenze che compongono query malevole prima che vengano elaborate.
- **Query Parametrizzate (*Prepared Statements*):** È il metodo più efficace. Consiste nello scrivere il codice SQL in modo che il database tratti i dati inseriti dall'utente solo come semplici parametri testuali e mai come comandi eseguibili, neutralizzando così l'attacco alla radice.